



Coverity® Security Report

Biometric internal API security related improvement v. 2026

Enterprise	BL
Technology	BSS
Assurance Level	AL1 (90)
Severity Mapping	Carrier grade
Prepared For	BSS
Prepared By	shahriar.hussain
Prepared On	Jul 19, 2026 3:33 PM

Executive Summary

This report details the application security assessment activities that were carried out, providing a summary of findings, compliance against published policy requirements, and remediation actions required. Also provided is a detailed breakdown and cross reference between technical findings and Coverity analysis results.

The intended audience for this report is an application security assurance team and their clients or end users. To review detailed code-level findings, it is recommended that developers click [this link to the Coverity Connect platform](http://172.18.0.8:8080/reports#p10781) (http://172.18.0.8:8080/reports#p10781) in order to see source code annotated with remediation recommendations.

Lines of Code Inspected: 89656

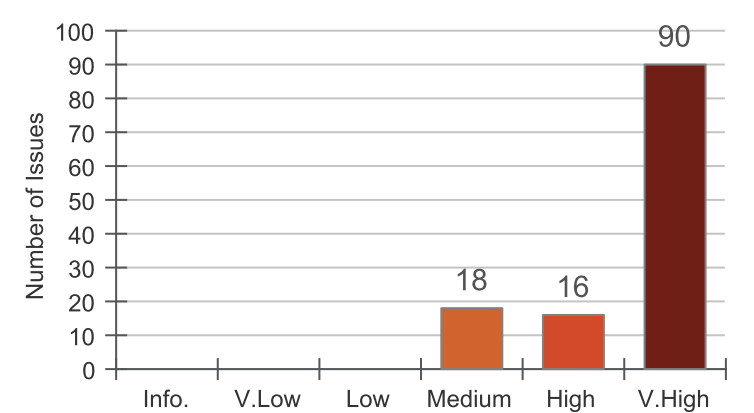
Scorecard

The issues were evaluated according to each element of the report's policy. The results are shown in the table below. An overall status of "pass" is assigned if all the policy elements passed.

Policy Element	Target	Value	Passed
Security Score	90	50	No
OWASP Top 10 Count	0	87	No
CWE/SANS Top 25 Count	0	17	No
Analysis Date	2026-6-19	2026-7-19	Yes
Overall Status			No

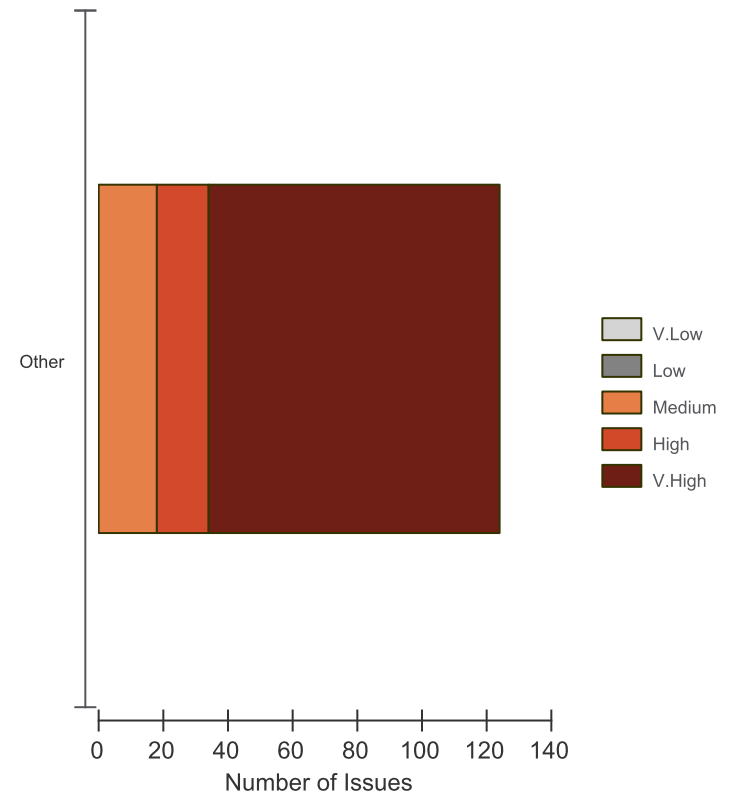
Issues By Severity

A total of 124 security issues were found. Each issue was given a severity based on the severity mapping. The chart below shows the number of occurrences of each of the six severity values.



Severity By Component

Issues are shown grouped by severity and counted by Component.



Additional Quality Measures

This table reports the numbers of issues of various categories that were not included in the Security Score calculation. Although they were excluded from the report, they may nonetheless indicate the presence of significant quality or security issues. Issues which do not have CWE number or Technical impact are counted as Non-Security issues.

Category	Count
Issues Marked "False Positive" or "Intentional"	0
Non-Security Issues	3
Issues Scored as "Informational"	0

Action Items

The code base was evaluated based on the policy in force. The policy has the following elements:

- The Security Score must meet or exceed the target set by the Assurance Level. See the [Security Details](#) section for more information.
- There must be no OWASP Top 10 issues among those found in the project. See the [OWASP Top 10](#) section for details.
- There must be no CWE/SANS Top 25 issues among those found in the project. See the [CWE/SANS Top 25](#) section for details.
- All snapshots must have been analyzed within 30 days. See the [Analysis Details](#) section for more information.

Coverity recommends the following actions in order to resolve critical outstanding issues, achieve compliance with policy, and improve the overall security of the software.

Security Score Remediation

Resolve issues that contribute to a substandard security score. Resolving the issues below will improve the security score from 50 to 90:

- 90 "Very high" issues.
- 16 "High" issues.
- 16 "Medium" issues.

OWASP Top 10 Remediation

Resolve 87 issues that are present in the OWASP Top 10. See the [OWASP Top 10](#) Section for a list of them.

CWE/SANS Top 25 Remediation

Resolve 17 issues that are present in the CWE/SANS Top 25. See the [CWE/SANS Top 25](#) Section for a list of them.

Recent Source Code Analysis

Regular source code analysis is key to identifying security issues in a timely manner and to ensuring that these issues are effectively eliminated, in-line with development activities.

The current results are sufficiently recent (less than 30 days old).

Long Term and Residual Risk Management

Review and consider broader improvement to the overall security posture of the target application.

Review outstanding lesser-rated issues to ensure minimal residual risk.

Review issues marked false positive to be sure that a coding change will not eliminate them.

Review any security issues marked Informational to see if some are in fact credible threats.

Review and correct non-security issues found by Coverity Analysis, in order to increase the overall quality of the code.

Security Details

The severity mapping shows how technical impacts (possible security flaws) are paired with severities. This severity mapping table also shows the number of issues for each technical impact.

Severity Mapping Name: Carrier grade

Severity Mapping Description: Very stringent

Technical Impact	Severity	Number of Issues
Execute unauthorized code	Very high	82
Gain privileges	Very high	8
Bypass protection mechanism	High	4
Denial of service, unreliable execution	High	3
Modify data	High	9
Denial of service, Resource consumption	Medium	18
Hide activities	Medium	0
Read data	Medium	0
Total		124

Coverity® Security Report

4

Analysis Details

A Coverity project is a collection of one or more streams containing separately-analyzed snapshots. The latest snapshot in each stream is used when reporting results for a project. This section gives details about the streams and the analysis performed for each snapshot.

Stream Name	Snapshot ID	Analysis Date	Analysis Version	Target
biometric-app-api-core-code_scan-19.7.26	10963	2026-7-19 3:17:45 PM	2026.6.0	

The 2017 OWASP Top 10 List

The [Open Web Application Security Project](#) (OWASP) is an open community dedicated to enabling organizations to conceive, develop, acquire, operate, and maintain applications that can be trusted. The OWASP maintains the [OWASP Top 10 List for 2017](#), a prioritized list of security weaknesses. OWASP says, "We can no longer afford to tolerate relatively simple security problems like those presented in this OWASP Top 10."

Each entry in the OWASP Top 10 refers to a set of CWE entries. Those entries may be individual weaknesses or families of weaknesses. See [the next section](#) for further discussion.

The table below shows the number of issues found in each category of the OWASP Top 10 for 2017.

2017 OWASP Top 10 Categories	CWE Number	Count
1. Injection	1027	0
2. Broken Authentication	1028	0
3. Sensitive Data Exposure	1029	18
4. XML External Entities (XXE)	1030	0
5. Broken Access Control	1031	69
6. Security Misconfiguration	1032	0
7. Cross-Site Scripting (XSS)	1033	0
8. Insecure Deserialization	1034	0
9. Using Components with Known Vulnerabilities *	1035	0
10. Insufficient Logging & Monitoring	1036	0
Total		87

* Category 9 of the OWASP Top 10 for 2017, "Using Components with Known Vulnerabilities," is not detected by Coverity Static Analysis, but is detected by BlackDuck and Protecode ES, which are other Black Duck Software products.

Coverity® Security Report

5

The 2019 CWE/SANS Top 25 List

The Common Weakness Enumeration is a community-developed dictionary of software weakness types. The [2019 CWE/SANS Top 25 Most Dangerous Software Errors](#) (or, "Top 25") is a list of weaknesses, taken from the CWE, that are thought to be the most widespread and critical errors that can lead to serious vulnerabilities in software.

Each category in the Top 25 List mentions one primary CWE identifier (CWE ID). Such a CWE ID can refer to an individual weakness or to a family of related weaknesses, since a given CWE ID may have children CWE IDs, which in turn may have children CWE IDs of their own. A Coverity issue corresponds to the most relevant CWE ID. A CWE/SANS Top 25 Category will consist of all of the Coverity issues that correspond to either the mentioned CWE ID or to one of its associated descendants.

The table below lists all the entries of the Top 25 and shows how many Coverity issues in the current project were found to be members of the Top 25.

2019 CWE/SANS Top 25 Categories	CWE Number	Count
1. Improper Restriction of Operations within the Bounds of a Memory Buffer	CWE-119	0
2. Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting')	CWE-79	0
3. Improper Input Validation	CWE-20	0
4. Information Exposure	CWE-200	0
5. Out-of-bounds Read	CWE-125	0
6. Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')	CWE-89	0
7. Use After Free	CWE-416	0
8. Integer Overflow or Wraparound	CWE-190	0
9. Cross-Site Request Forgery (CSRF)	CWE-352	0
10. Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')	CWE-22	0
11. Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection')	CWE-78	0
12. Out-of-bounds Write	CWE-787	0
13. Improper Authentication	CWE-287	0
14. NULL Pointer Dereference	CWE-476	11
15. Incorrect Permission Assignment for Critical Resource	CWE-732	0
16. Unrestricted Upload of File with Dangerous Type	CWE-434	0
17. Improper Restriction of XML External Entity Reference ('XXE')	CWE-611	0
18. Improper Control of Generation of Code ('Code Injection')	CWE-94	0
19. Use of Hard-coded Credentials	CWE-798	6
20. Uncontrolled Resource Consumption ('Resource Exhaustion')	CWE-400	0
21. Missing Release of Resource after Effective Lifetime	CWE-772	0
22. Untrusted Search Path	CWE-426	0
23. Deserialization of Untrusted Data	CWE-502	0
24. Improper Privilege Management	CWE-269	0
25. Improper Certificate Validation	CWE-295	0
Total		17

Detailed Issues Ranked By Severity

Severity: Very high

Technical Impact: Execute unauthorized code

CWE 366: Race Condition within a Thread

Summary: If two threads of execution use a resource simultaneously, there exists the possibility that resources may be used while invalid, in turn making the state of execution undefined.

Remediation: Use locking functionality. This is the recommended solution. Implement some form of locking mechanism around code which alters or reads persistent data in a multithreaded environment.

Issue ID (CID) and Issue Type	Source File and Line Number	Component	Details
16404 Data race condition	/biometric-app-api-core-code_scan/BIA.BLL/BLLServices/BLLForbiddenWords.cs:17	Other	Impact: Medium Classification: Unclassified Action: Undecided IssueKind: Quality

CWE 393: Return of Wrong Status Code

Summary: A function or operation returns an incorrect return value or status code that does not indicate an error, but causes the product to modify its behavior based on the incorrect result.

Details: This can lead to unpredictable behavior. If the function is used to make security-critical decisions or provide security-critical information, then the wrong status code can cause the software to assume that an action is safe, even when it is not. [more details](#).

Issue ID (CID) and Issue Type	Source File and Line Number	Component	Details
17573 Shell pipe without pipefail option	/biometric-app-api-core-code_scan/Dockerfile:11	Other	Impact: Low Classification: Unclassified Action: Undecided IssueKind: Security

CWE 476: NULL Pointer Dereference

This is categorized under the 14 in the [CWE/SANS Top 25](#).

Summary: A NULL pointer dereference occurs when the application dereferences a pointer that it expects to be valid, but is NULL, typically causing a crash or exit.

Details: NULL pointer dereference issues can occur through a number of flaws, including race conditions, and simple programming omissions. [more details](#).

Remediation: If all pointers that could have been modified are sanity-checked previous to use, nearly all NULL pointer dereferences can be prevented.

Issue ID (CID) and Issue Type	Source File and Line Number	Component	Details
17843 Dereference null return value	/biometric-app-api-core-code_scan/BIA/Controllers/CommonController.cs: 8287	Other	Impact: Medium Classification: Unclassified Action: Undecided IssueKind: Quality

Technical Impact: Execute unauthorized code

CWE 476: NULL Pointer Dereference

This is categorized under the 14 in the [CWE/SANS Top 25](#).

Summary: A NULL pointer dereference occurs when the application dereferences a pointer that it expects to be valid, but is NULL, typically causing a crash or exit.

Details: NULL pointer dereference issues can occur through a number of flaws, including race conditions, and simple programming omissions. [more details](#).

Remediation: If all pointers that could have been modified are sanity-checked previous to use, nearly all NULL pointer dereferences can be prevented.

Issue ID (CID) and Issue Type	Source File and Line Number	Component	Details
17842 Dereference null return value	/biometric-app-api-core-code_scan/BIA/Controllers/CommonController.cs: 1784	Other	Impact: Medium Classification: Unclassified Action: Undecided IssueKind: Quality
17839 Dereference null return value	/biometric-app-api-core-code_scan/BIA/Controllers/CommonController.cs: 8394	Other	Impact: Medium Classification: Unclassified Action: Undecided IssueKind: Quality
17795 Dereference before null check	/biometric-app-api-core-code_scan/BIA.BLL/BLLServices/BLLHomeWifiService.cs:305	Other	Impact: Medium Classification: Unclassified Action: Undecided IssueKind: Quality
17569 Dereference after null check	/biometric-app-api-core-code_scan/BIA/Controllers/DBSSNotificationController.cs:114	Other	Impact: Medium Classification: Unclassified Action: Undecided IssueKind: Quality
17566 Dereference after null check	/biometric-app-api-core-code_scan/BIA.BLL/BLLServices/BLLUserAuthenticaiton.cs:189	Other	Impact: Medium Classification: Unclassified Action: Undecided IssueKind: Quality
17557 Dereference before null check	/biometric-app-api-core-code_scan/BIA/Controllers/SecurityController.cs: 1866	Other	Impact: Medium Classification: Unclassified Action: Undecided IssueKind: Quality
17552 Dereference after null check	/biometric-app-api-core-code_scan/BIA/Controllers/SecurityController.cs: 1854	Other	Impact: Medium Classification: Unclassified Action: Undecided IssueKind: Quality
16604 Dereference after null check	/biometric-app-api-core-code_scan/BIA.BLL/BLLServices/BLLDBSSToRAParse.cs:1610	Other	Impact: Medium Classification: Unclassified Action: Undecided IssueKind: Quality
16598 Dereference after null check	/biometric-app-api-core-code_scan/BIA.BLL/BLLServices/BLLDBSSToRAParse.cs:1549	Other	Impact: Medium Classification: Unclassified Action: Undecided IssueKind: Quality
16403 Dereference after null check	/biometric-app-api-core-code_scan/BIA/Controllers/DBSSNotificationController.cs:343	Other	Impact: Medium Classification: Unclassified Action: Undecided IssueKind: Quality

Technical Impact: Execute unauthorized code

CWE 915: Improperly Controlled Modification of Dynamically-Determined Object Attributes

This is categorized under the 5 in the [OWASP Top 10](#).

Summary: The software receives input from an upstream component that specifies multiple attributes, properties, or fields that are to be initialized or updated in an object, but it does not properly control which attributes can be modified.

Details: If the object contains attributes that were only intended for internal use, then their unexpected modification could lead to a vulnerability. [more details](#).

Remediation: If available, use features of the language or framework that allow specification of whitelists of attributes or fields that are allowed to be modified. If possible, prefer whitelists over black lists.

Issue ID (CID) and Issue Type	Source File and Line Number	Component	Details
17841 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/StarTrekCommonController.cs:1136	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
17840 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/StarTrekCommonController.cs:935	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
17838 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/CommonController.cs:6076	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
17804 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/HomeWifiController.cs:1829	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
17584 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/HomeWifiController.cs:481	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
17582 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/HomeWifiController.cs:170	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
17580 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/HomeWifiController.cs:1017	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
17574 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/HomeWifiController.cs:750	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
17570 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/HomeWifiController.cs:144	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
17560 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/HomeWifiController.cs:1421	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
17559 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/HomeWifiController.cs:1618	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security

Technical Impact: Execute unauthorized code

CWE 915: Improperly Controlled Modification of Dynamically-Determined Object Attributes

This is categorized under the 5 in the [OWASP Top 10](#).

Summary: The software receives input from an upstream component that specifies multiple attributes, properties, or fields that are to be initialized or updated in an object, but it does not properly control which attributes can be modified.

Details: If the object contains attributes that were only intended for internal use, then their unexpected modification could lead to a vulnerability. [more details](#).

Remediation: If available, use features of the language or framework that allow specification of whitelists of attributes or fields that are allowed to be modified. If possible, prefer whitelists over black lists.

Issue ID (CID) and Issue Type	Source File and Line Number	Component	Details
16603 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/MNPController.cs: 4333	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
16602 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/MNPController.cs: 4905	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
16601 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/CommonController.cs: 1108	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
16600 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/DBSSNotificationController.cs:55	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
16599 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/CommonController.cs: 1694	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
16597 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/CommonController.cs: 221	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
16596 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/CommonController.cs: 2004	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
16595 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/MNPController.cs:356	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
16594 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/MNPController.cs:654	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
16282 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/NewConnectionController.cs:1639	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
16281 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/CherishNewConnectionController.cs:53	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security

Technical Impact: Execute unauthorized code**CWE 915: Improperly Controlled Modification of Dynamically-Determined Object Attributes**

This is categorized under the 5 in the [OWASP Top 10](#).

Summary: The software receives input from an upstream component that specifies multiple attributes, properties, or fields that are to be initialized or updated in an object, but it does not properly control which attributes can be modified.

Details: If the object contains attributes that were only intended for internal use, then their unexpected modification could lead to a vulnerability. [more details](#).

Remediation: If available, use features of the language or framework that allow specification of whitelists of attributes or fields that are allowed to be modified. If possible, prefer whitelists over black lists.

Issue ID (CID) and Issue Type	Source File and Line Number	Component	Details
16280 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/ NewConnectionController.cs:448	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
16279 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/ NewConnectionController.cs:908	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
16278 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/ FirstRechargeController.cs:1109	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
16277 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/ CherishNewConnectionController.cs:452	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
16276 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/ FirstRechargeController.cs:52	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
16275 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/ StarTrekNewConnectionController.cs:495	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
16274 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/ FirstRechargeController.cs:620	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
14234 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/ StarTrekSIMReplacementController.cs:50	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
14233 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/ SimReplacementController.cs:1343	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
14232 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/ StarTrekNewConnectionController.cs:83	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
14231 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/ StarTrekSIMReplacementController.cs:344	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security

Technical Impact: Execute unauthorized code**CWE 915: Improperly Controlled Modification of Dynamically-Determined Object Attributes**

This is categorized under the 5 in the [OWASP Top 10](#).

Summary: The software receives input from an upstream component that specifies multiple attributes, properties, or fields that are to be initialized or updated in an object, but it does not properly control which attributes can be modified.

Details: If the object contains attributes that were only intended for internal use, then their unexpected modification could lead to a vulnerability. [more details](#).

Remediation: If available, use features of the language or framework that allow specification of whitelists of attributes or fields that are allowed to be modified. If possible, prefer whitelists over black lists.

Issue ID (CID) and Issue Type	Source File and Line Number	Component	Details
14230 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/ ResubmitController.cs:56	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
14229 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/ StarTrekNewConnectionController.cs:910	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
14228 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/ SimCategoryMigrationController.cs:553	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
14227 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/ SimReplacementController.cs:1630	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
14226 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/ StarTrekMNPCController.cs:55	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
14225 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/MNPCController.cs: 2082	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
14224 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/ DBSSNotificationController.cs:284	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
14223 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/POCController.cs:266	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
14222 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/MNPCController.cs: 1592	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
14221 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/TOSController.cs: 1732	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
14220 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/ StarTrekNewConnectionController.cs:1717	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security

Technical Impact: Execute unauthorized code**CWE 915: Improperly Controlled Modification of Dynamically-Determined Object Attributes**

This is categorized under the 5 in the [OWASP Top 10](#).

Summary: The software receives input from an upstream component that specifies multiple attributes, properties, or fields that are to be initialized or updated in an object, but it does not properly control which attributes can be modified.

Details: If the object contains attributes that were only intended for internal use, then their unexpected modification could lead to a vulnerability [more details](#).

Remediation: If available, use features of the language or framework that allow specification of whitelists of attributes or fields that are allowed to be modified. If possible, prefer whitelists over black lists.

Issue ID (CID) and Issue Type	Source File and Line Number	Component	Details
14218 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/ BioCancellationController.cs:1062	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
14217 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/ SimReplacementController.cs:1033	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
14216 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/FPBaseController.cs: 751	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
14215 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/POCController.cs:79	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
14214 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/ RetailerSyncController.cs:57	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
14213 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/ StarTrekNewConnectionController.cs:1307	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
14212 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/ SimCategoryMigrationController.cs:348	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
14211 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/ DBSSNotificationController.cs:514	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
14210 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/ SimReplacementController.cs:1910	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
14209 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/ NewConnectionController.cs:90	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
14208 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/ NewConnectionController.cs:1283	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security

Technical Impact: Execute unauthorized code**CWE 915: Improperly Controlled Modification of Dynamically-Determined Object Attributes**

This is categorized under the 5 in the [OWASP Top 10](#).

Summary: The software receives input from an upstream component that specifies multiple attributes, properties, or fields that are to be initialized or updated in an object, but it does not properly control which attributes can be modified.

Details: If the object contains attributes that were only intended for internal use, then their unexpected modification could lead to a vulnerability [more details](#).

Remediation: If available, use features of the language or framework that allow specification of whitelists of attributes or fields that are allowed to be modified. If possible, prefer whitelists over black lists.

Issue ID (CID) and Issue Type	Source File and Line Number	Component	Details
14207 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/ StarTrekMNPCController.cs:268	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
12479 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/ CherishNewConnectionController.cs:799	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
12020 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/ SimCategoryMigrationController.cs:896	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
12014 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/TOSController.cs: 4109	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
12008 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/ NewConnectionController.cs:2070	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
11962 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/ SimReplacementController.cs:2165	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
11961 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/FPBaseController.cs: 1140	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
11956 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/ StarTrekSIMReplacementController.cs:699	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
11948 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/ StarTrekNewConnectionController.cs:2069	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
11940 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/ TwoPartyController.cs:251	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
11939 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/ StarTrekMNPCController.cs:837	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security

Technical Impact: Execute unauthorized code

CWE 915: Improperly Controlled Modification of Dynamically-Determined Object Attributes

This is categorized under the 5 in the [OWASP Top 10](#).

Summary: The software receives input from an upstream component that specifies multiple attributes, properties, or fields that are to be initialized or updated in an object, but it does not properly control which attributes can be modified.

Details: If the object contains attributes that were only intended for internal use, then their unexpected modification could lead to a vulnerability [more details](#).

Remediation: If available, use features of the language or framework that allow specification of whitelists of attributes or fields that are allowed to be modified. If possible, prefer whitelists over black lists.

Issue ID (CID) and Issue Type	Source File and Line Number	Component	Details
11936 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/POCController.cs:458	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
11934 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/BioCancellationController.cs:1258	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security
11931 Mass assignment	/biometric-app-api-core-code_scan/BIA/Controllers/MNPCController.cs:5095	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Security

Technical Impact: Gain privileges

CWE 310: Cryptographic Issues

Summary: Weaknesses in this category are related to the use of cryptography.

Issue ID (CID) and Issue Type	Source File and Line Number	Component	Details
13882 Insecure block cipher mode	/biometric-app-api-core-code_scan/BIA.Entity/Utility/Cryptography.cs:58	Other	Impact: Medium Classification: Unclassified Action: Undecided IssueKind: Security
13880 Insecure block cipher mode	/biometric-app-api-core-code_scan/BIA.Entity/Utility/Cryptography.cs:116	Other	Impact: Medium Classification: Unclassified Action: Undecided IssueKind: Security

Technical Impact: Gain privileges

CWE 321: Use of Hard-coded Cryptographic Key

This is categorized under the 3 in the [OWASP Top 10](#).

This is categorized under the 19 in the [CWE/SANS Top 25](#).

Summary: The use of a hard-coded cryptographic key significantly increases the possibility that encrypted data may be recovered.

Remediation: Prevention schemes mirror that of hard-coded password storage.

Issue ID (CID) and Issue Type	Source File and Line Number	Component	Details
13881 Use of hard-coded cryptographic key	/biometric-app-api-core-code_scan/BIA.Entity/Utility/Cryptography.cs:292	Other	Impact: Medium Classification: Unclassified Action: Undecided IssueKind: Security
13878 Use of hard-coded cryptographic key	/biometric-app-api-core-code_scan/BIA.Entity/Utility/Cryptography.cs:290	Other	Impact: Medium Classification: Unclassified Action: Undecided IssueKind: Security
13875 Use of hard-coded cryptographic key	/biometric-app-api-core-code_scan/BIA.Entity/Utility/Cryptography.cs:327	Other	Impact: Medium Classification: Unclassified Action: Undecided IssueKind: Security
13874 Use of hard-coded cryptographic key	/biometric-app-api-core-code_scan/BIA.Entity/Utility/Cryptography.cs:329	Other	Impact: Medium Classification: Unclassified Action: Undecided IssueKind: Security
13871 Use of hard-coded cryptographic key	/biometric-app-api-core-code_scan/BIA.Entity/Utility/Cryptography.cs:112	Other	Impact: Medium Classification: Unclassified Action: Undecided IssueKind: Security
13868 Use of hard-coded cryptographic key	/biometric-app-api-core-code_scan/BIA.Entity/Utility/Cryptography.cs:55	Other	Impact: Medium Classification: Unclassified Action: Undecided IssueKind: Security

Severity: High

Technical Impact: Bypass protection mechanism

CWE 328: Reversible One-Way Hash

This is categorized under the 3 in the [OWASP Top 10](#).

Summary: The product uses a hashing algorithm that produces a hash value that can be used to determine the original input, or to find an input that can produce the same hash, more efficiently than brute force techniques.

Details: This weakness is especially dangerous when the hash is used in security algorithms that require the one-way property to hold. For example, if an authentication system takes an incoming password and generates a hash, then compares the hash to another hash that it has stored in its authentication database, then the ability to create a collision could allow an attacker to provide an alternate password that produces the same target hash, bypassing authentication. [more details](#).

Remediation: Use an adaptive hash function that can be configured to change the amount of computational effort needed to compute the hash, such as the number of iterations ("stretching") or the amount of memory required. Some hash functions perform salting automatically. These functions can significantly increase the overhead for a brute force attack compared to intentionally-fast functions such as MD5. For example, rainbow table attacks can become infeasible due to the high computing overhead. Finally, since computing power gets faster and cheaper over time, the technique can be reconfigured to increase the workload without forcing an entire replacement of the algorithm in use.

Issue ID (CID) and Issue Type	Source File and Line Number	Component	Details
12344 Risky cryptographic hashing function	/biometric-app-api-core-code_scan/BIA.Entity/Utility/Cryptography.cs:98	Other	Impact: Medium Classification: Unclassified Action: Undecided IssueKind: Security
12342 Risky cryptographic hashing function	/biometric-app-api-core-code_scan/BIA.Entity/Utility/Cryptography.cs:43	Other	Impact: Medium Classification: Unclassified Action: Undecided IssueKind: Security
12334 Risky cryptographic hashing function	/biometric-app-api-core-code_scan/BIA.Entity/Utility/Cryptography.cs:24	Other	Impact: Medium Classification: Unclassified Action: Undecided IssueKind: Security
12333 Risky cryptographic hashing function	/biometric-app-api-core-code_scan/BIA.Entity/Utility/Cryptography.cs:208	Other	Impact: Medium Classification: Unclassified Action: Undecided IssueKind: Security

Technical Impact: Denial of service, unreliable execution

CWE 563: Assignment to Variable without Use

Summary: The variable's value is assigned but never used, making it a dead store.

Details: After the assignment, the variable is either assigned another value or goes out of scope. It is likely that the variable is simply vestigial, but it is also possible that the unused variable points out a bug.[more details](#).

Remediation: Remove unused variables from the code.

Issue ID (CID) and Issue Type	Source File and Line Number	Component	Details
17792 Unused value	/biometric-app-api-core-code_scan/BIA/Helper/CustomAuthorizationFilter.cs:22	Other	Impact: Low Classification: Unclassified Action: Undecided IssueKind: Quality
17583 Unused value	/biometric-app-api-core-code_scan/BIA/Helper/StarTrekNewConnectionRequestValidator.cs:25	Other	Impact: Medium Classification: Unclassified Action: Undecided IssueKind: Quality
17554 Unused value	/biometric-app-api-core-code_scan/BIA/Helper/StarTrekCherishNewConnectionRequestValidator.cs:22	Other	Impact: Medium Classification: Unclassified Action: Undecided IssueKind: Quality

Technical Impact: Modify data

CWE 327: Use of a Broken or Risky Cryptographic Algorithm

This is categorized under the 3 in the [OWASP Top 10](#).

Summary: The use of a broken or risky cryptographic algorithm is an unnecessary risk that may result in the exposure of sensitive information.

Details: The use of a non-standard algorithm is dangerous because a determined attacker may be able to break the algorithm and compromise whatever data has been protected. Well-known techniques may exist to break the algorithm.[more details](#).

Remediation: When there is a need to store or transmit sensitive data, use strong, up-to-date cryptographic algorithms to encrypt that data. Select a well-vetted algorithm that is currently considered to be strong by experts in the field, and use well-tested implementations. As with all cryptographic mechanisms, the source code should be available for analysis.

Issue ID (CID) and Issue Type	Source File and Line Number	Component	Details
13887 Weak hash algorithm	/biometric-app-api-core-code_scan/BIA.Entity/Utility/Cryptography.cs:24	Other	Impact: Low Classification: Unclassified Action: Undecided IssueKind: Security
13886 Insecure block cipher algorithm	/biometric-app-api-core-code_scan/BIA.Entity/Utility/Cryptography.cs:53	Other	Impact: Medium Classification: Unclassified Action: Undecided IssueKind: Security
13885 Weak hash algorithm	/biometric-app-api-core-code_scan/BIA.Entity/Utility/Cryptography.cs:98	Other	Impact: Low Classification: Unclassified Action: Undecided IssueKind: Security

Technical Impact: Modify data

CWE 327: Use of a Broken or Risky Cryptographic Algorithm

This is categorized under the 3 in the [OWASP Top 10](#).

Summary: The use of a broken or risky cryptographic algorithm is an unnecessary risk that may result in the exposure of sensitive information.

Details: The use of a non-standard algorithm is dangerous because a determined attacker may be able to break the algorithm and compromise whatever data has been protected. Well-known techniques may exist to break the algorithm. [more details](#).

Remediation: When there is a need to store or transmit sensitive data, use strong, up-to-date cryptographic algorithms to encrypt that data. Select a well-vetted algorithm that is currently considered to be strong by experts in the field, and use well-tested implementations. As with all cryptographic mechanisms, the source code should be available for analysis.

Issue ID (CID) and Issue Type	Source File and Line Number	Component	Details
13876 Weak hash algorithm	/biometric-app-api-core-code_scan/BIA.Entity/Utility/Cryptography.cs:208	Other	Impact: Low Classification: Unclassified Action: Undecided IssueKind: Security
13873 Weak hash algorithm	/biometric-app-api-core-code_scan/BIA.Entity/Utility/Cryptography.cs:43	Other	Impact: Low Classification: Unclassified Action: Undecided IssueKind: Security
13872 Insecure block cipher algorithm	/biometric-app-api-core-code_scan/BIA.Entity/Utility/Cryptography.cs:110	Other	Impact: Medium Classification: Unclassified Action: Undecided IssueKind: Security
12341 Risky cryptographic function	/biometric-app-api-core-code_scan/BIA.Entity/Utility/Cryptography.cs:110	Other	Impact: Medium Classification: Unclassified Action: Undecided IssueKind: Security
12335 Risky cryptographic function	/biometric-app-api-core-code_scan/BIA.Entity/Utility/Cryptography.cs:53	Other	Impact: Medium Classification: Unclassified Action: Undecided IssueKind: Security

CWE 543: Use of Singleton Pattern Without Synchronization in a Multithreaded Context

Summary: The software uses the singleton pattern when creating a resource within a multithreaded environment.

Details: The use of a singleton pattern may not be thread-safe. [more details](#).

Remediation: Use the Thread-Specific Storage Pattern. See References.

Issue ID (CID) and Issue Type	Source File and Line Number	Component	Details
16405 Check of thread-shared field evades lock acquisition	/biometric-app-api-core-code_scan/BIA.BLL/BLLServices/BLLForbiddenWords.cs:17	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Quality

Severity: Medium

Technical Impact: Denial of service, Resource consumption

CWE 404: Improper Resource Shutdown or Release

Summary: The program does not release or incorrectly releases a resource before it is made available for re-use.

Details: When a resource is created or allocated, the developer is responsible for properly releasing the resource as well as accounting for all potential paths of expiration or invalidation, such as a set period of time or revocation.[more details](#).

Remediation: Use a language that does not allow this weakness to occur or provides constructs that make this weakness easier to avoid.

Issue ID (CID) and Issue Type	Source File and Line Number	Component	Details
17837 Resource leak	/biometric-app-api-core-code_scan/BIA.BLL/Utility/ApiCall.cs:536	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Quality
17836 Resource leak	/biometric-app-api-core-code_scan/BIA.BLL/Utility/ApiCall.cs:1918	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Quality
17835 Resource leak	/biometric-app-api-core-code_scan/BIA.BLL/BLLServices/BLLHomeWifiService.cs:2153	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Quality
17807 Resource leak	/biometric-app-api-core-code_scan/BIA.BLL/BLLServices/BLLHomeWifiService.cs:163	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Quality
17797 Resource leak	/biometric-app-api-core-code_scan/BIA.BLL/BLLServices/BLLHomeWifiService.cs:4011	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Quality
17794 Resource leak	/biometric-app-api-core-code_scan/BIA.BLL/BLLServices/BLLHomeWifiService.cs:483	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Quality
17592 Resource leak	/biometric-app-api-core-code_scan/BIA.BLL/BLLServices/BLLHomeWifiService.cs:925	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Quality
17587 Resource leak	/biometric-app-api-core-code_scan/BIA/Middleware/HttpListenerLog.cs:118	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Quality
17585 Resource leak	/biometric-app-api-core-code_scan/BIA/Helper/CustomAuthorizationFilterInternal.cs:107	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Quality
17575 Resource leak	/biometric-app-api-core-code_scan/BIA.BLL/BLLServices/BLLHomeWifiService.cs:2607	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Quality
17571 Resource leak	/biometric-app-api-core-code_scan/BIA.BLL/BLLServices/BLLHomeWifiService.cs:3190	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Quality

Technical Impact: Denial of service, Resource consumption

CWE 404: Improper Resource Shutdown or Release

Summary: The program does not release or incorrectly releases a resource before it is made available for re-use.

Details: When a resource is created or allocated, the developer is responsible for properly releasing the resource as well as accounting for all potential paths of expiration or invalidation, such as a set period of time or revocation. [more details](#).

Remediation: Use a language that does not allow this weakness to occur or provides constructs that make this weakness easier to avoid.

Issue ID (CID) and Issue Type	Source File and Line Number	Component	Details
17567 Resource leak	/biometric-app-api-core-code_scan/BIA.BLL/BLLServices/BLLHomeWifiService.cs:59	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Quality
17562 Resource leak	/biometric-app-api-core-code_scan/BIA.BLL/BLLServices/BLLHomeWifiService.cs:1887	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Quality
17558 Resource leak	/biometric-app-api-core-code_scan/BIA.BLL/BLLServices/BLLHomeWifiService.cs:1520	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Quality
17555 Resource leak	/biometric-app-api-core-code_scan/BIA.Middleware/SerilogGlobalHandler.cs:104	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Quality
16406 Resource leak	/biometric-app-api-core-code_scan/BIA.DAL/Repositories/DALForbiddenWords.cs:40	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Quality
13884 Resource leak	/biometric-app-api-core-code_scan/BIA/Helper/FP_Matching.cs:75	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Quality
11738 Resource leak	/biometric-app-api-core-code_scan/BIA.Entity/Utility/Cryptography.cs:31	Other	Impact: High Classification: Unclassified Action: Undecided IssueKind: Quality

Methodology

Introduction

This report is a distillation of the output of the Coverity Code Advisor used on a particular code source base. Coverity Code Advisor is a static analysis tool that is capable of finding quality defects, security vulnerabilities, and test violations through the process of scanning the output of a specially-compiled code base. The information in this report is specific to security vulnerabilities detected by Coverity Code Advisor and their categorization in the OWASP and CWE/SANS ranking systems.

About Static Analysis

Static analysis is the analysis of software code without executing the compiled program, for the purpose of finding logic errors or security vulnerabilities. Coverity's static analysis tools integrate with all major build systems and generate a high fidelity representation of source code to provide full code path coverage, ensuring that every line of code and execution path is analyzed. Code Advisor supports the market-leading compilers for C, C++, Java, C#, Objective C, and Javascript.

About CWE

CWE ([Common Weakness Enumeration](#)) is a software community project that is responsible for creating a catalog of software weaknesses and vulnerabilities and is sponsored by the office of Cybersecurity and Communications at the U.S. Department of Homeland Security. The Common Weakness Scoring System (CWSS) provides a method by which to identify and compare weaknesses.

CWE is used by vulnerability-listing efforts such as [CWE/SANS Top 25](#) and [OWASP Top 10](#), among others, to create generalized lists of ranked vulnerabilities. Some, but not all, of the issues reported by Coverity are mapped to CWE-listed vulnerabilities. The [Common Weakness Risk Assessment Framework](#) (CWRAF) is a methodology for prioritizing software weaknesses in the context of the software's use. A CWRAF "severity mapping" prioritizes issues according to their CWE technical impact values. There are 8 technical impacts:

1. modify data,
2. read data,
3. create a denial-of-service that results in unreliable execution,
4. create a denial-of-service that results in resource consumption,
5. execute unauthorized code or commands,
6. gain privileges or assume identity,
7. bypass protection mechanism,
8. hide activities

CWRAF and CWSS allow users to rank classes of weaknesses independently of any particular software package, in order to prioritize them relative to each other.

Setting Priorities with Severity Mappings

A severity mapping is a mapping that determines a severity level, or score, for a given technical impact associated with a software issue. This score can in turn be used to derive the priority assigned to the remediation of the issue. Coverity provides built-in severity mappings to help customers to set these priorities for particular types of applications, and the ability to create custom severity mappings.

The part of the severity mapping that's relevant for this work is the Technical Impact Scorecard. It maps a technical impact to a severity value between Informational (the lowest) and Very High (the highest). This value is known variously as the technical impact's "score" or its "severity". This document uses "severity".

Scoring Methodology

An issue from Coverity's code analysis will contribute to the security score when it has a CWE ID where the CWE ID maps to at least one of the eight technical impact values, at least one the mapped technical impact values has a severity level greater than Informational, and the issue has not been marked as "False Positive" or "Intentional". A severity mapping determines the mapping of technical impact values to severity levels and it is an issue's assigned severity level that is used for the security score calculation. For an issue where its CWE ID maps to more than one of the eight technical impact values, a single technical impact value will be assigned to the issue, where the highest relevant severity level will determine which technical impact value gets assigned, with ties for the highest severity level being broken arbitrarily.

The severity levels from the [Security Details](#) section are used to determine the security score, with the possible severity levels being Very High, High, Medium, Low, and Very Low. The highest severity level that has at least one issue associated with it will greatly influence the security score. Additional issues with the highest severity level will have a greater impact on reducing the security score than will additional issues with a relatively lower severity level. As such, it's important to address issues with the highest severity level.

While the full range of a possible security score is from 0 to 100, with 100 being the best value possible, only a project with a highest severity level of Very Low that contains 6 or less Very Low severity level issues can receive a score of 100. A project would need to contain more than 30000 Very High severity level issues to receive a score lower than 30. Meanwhile, a project with a highest severity level of Very Low would need to contain more than 30000 Very Low severity level issues to receive a score lower than 70.

To give some further context, consider the standard Target Assurance Levels plus their corresponding Target Security Score values of AL1 (90), AL2 (80), AL3 (70), and AL4 (60) relative to the highest severity level that has at least one issue associated with it.

- If Very High severity level issues exist, it will be nearly impossible to achieve AL3 (70), and it will be quite a challenge to achieve AL4 (60).
- If all of the Very High severity level issues have been addressed, but at least one High severity level issue exists, it will be nearly impossible to achieve AL2 (80), and it will be a reasonable challenge to achieve AL3 (70), with AL4 (60) being within easier reach.
- If all of the Very High and High severity level issues have been addressed, but at least one Medium severity level issue exists, it will be nearly impossible to achieve AL1 (90) and quite challenging to achieve AL2 (80), while AL3 (70) is more likely to be within reach, and AL4 (60) should be a relatively easy target to reach.

The OWASP Top 10 List

The OWASP (Open Web Application Security Project) Foundation is an international organization whose mission is to advance the cause of secure software. As part of its activities, OWASP publishes a report of the most critical web application security flaws in rank order based on the input of a worldwide group of security experts. The most recent version of this list and accompanying report is the [OWASP Top 10 List for 2017](#). The OWASP Top 10 List is referenced by many standards including MITRE, PCI DSS, DISA, and the FTC.

The CWE/SANS Top 25 List

The SANS Institute is a cooperative research and education organization made up security experts from around the world. SANS is a major source of information on computer security and makes available an extensive collection of research documentation. It also operates the Internet's early security vulnerability warning system, the Internet Storm Center. The 2019 CWE/SANS Top 25 Most Dangerous Software Errors is a list of the most common and critical errors that can lead to software vulnerabilities, as published by this organization.

About Coverity

Coverity is a leading provider of quality and security testing solutions. The company, founded in the Computer Science Laboratory at Stanford University, provides an array of tools that assist developers in addressing critical quality and security issues early in the development cycle, thus saving development organizations from remediating issues late in the development cycle or after release when they are much more costly. Many major software development organizations, including 8 of the top 10 global brands and 9 of the top 10 software companies, deploy Coverity analysis tools. Coverity also maintains a free, cloud based analysis platform, called Scan, for the Open Source Community.